Evaluación de Vulnerabilidades CVE

ACTIVOS TECNOLÓGICOS:

Teléfonos IP

MODELO: Cisco IP Phone 8851

VULNERABILIDAD: **CVE-2021-1379**

CRITICIDAD: **MEDIA (6,5)**

DESCRIPCIÓN:

Los teléfonos IP de las series Cisco IP Phone 68xx/78xx/88xx han presentado múltiples vulnerabilidades, las cuales **podrían permitir que un atacante adyacente no autentificado ejecute código de forma remota o provoque un reinicio de un teléfono IP afectado.**

Estas vulnerabilidades se deben a la **falta de comprobaciones** cuando el teléfono IP procesa un protocolo de descubrimiento de Cisco o un paquete LLDP

Cisco Discovery Protocol es un protocolo de capa 2 propietario de Cisco. Su función principal es permitir que los dispositivos conectados entre sí se descubran mutuamente.

LLDP *(Link Layer Discovery Protocol)* es un protocolo estándar definido por la IEEE 802.1AB. Su propósito es permitir que los dispositivos de red anuncien información sobre si mismos a los dispositivos vecinos.

Para aprovechar estas vulnerabilidades, un atacante debe estar en el mismo dominio de difusión que el dispositivo afectado.

n exploit exitoso podría permitir al atacante ejecutar código en el teléfono IP afectado o hacer que se vuelva a cargar inesperadamente, lo que resultaría en una condición de denegación de servicio (DoS).

- **VECTOR DE ATAQUE**: Adyacente
- **COMPLEJIDAD DEL ATAQUE**: Bajo
- **PRIVILEGIOS REQUERIDOS:** Ninguno
- **INTERACCIÓN CON EL USUARIO:** Ninguno
- **ALCANCE:** Integrado
- **IMPACTO DE LA CONFIDENCIALIDAD:** Ninguno
- **IMPACTO EN LA INTEGRIDAD:** Ninguno
- **IMPACTO EN LA DISPONIBILIDAD:** Alto

CONTRAMEDIDAS:

- Desactivar CDP/LLDP en interfaces donde no se requiera
- Segmentar la red de telefonía en VLANs aisladas
- Actualizar el firmware del teléfono IP a la última versión disponible
- Monitorear tráfico de red para detectar paquetes LLDP/CDP anómalos

Computadoras/PCs

MODELO: Dell OptiPlex 5000 Micro Tower

VULNERABILIDAD: CVE-2023-28063

CRITICIDAD: **MEDIA (6,7)**

DESCRIPCIÓN:

Vulnerabilidad en BIOS por conversión incorrecta de valores firmados/no firmados. Permite denegación de servicio si el atacante tiene acceso local con privilegios.

Al introducir un número (especialmente uno negativo) en una variable que el BIOS interpreta como no firmada, puede producirse una conversión errónea que transforme ese valor en un número extremadamente grande. Esta mala interpretación puede derivar en un desbordamiento de memoria o de búfer, lo que a su vez podría comprometer el sistema, provocar fallos críticos o incluso neutralizar el dispositivo por completo.

- **VECTOR DE ATAQUE:** Local
- **COMPLEJIDAD DEL ATAQUE**: Bajo
- **PRIVILEGIOS REQUERIDOS:** Alto
- **INTERACCIÓN CON EL USUARIO:** Ninguno
- **ALCANCE:** Integrado
- **IMPACTO DE LA CONFIDENCIALIDAD:** Alto
- **IMPACTO EN LA INTEGRIDAD:** Alto
- **IMPACTO EN LA DISPONIBILIDAD:** Alto

MODELO: HP ProDesk 400 G7 SFF

VULNERABILIDAD: CVE-2022-31640

CRITICIDAD: **ALTO (7,0)**

DESCRIPCIÓN:

Vulnerabilidad de ejecución de código arbitrario y escalada de privilegios del BIOS de HP.

Se han identificado vulnerabilidades potenciales en el BIOS del sistema de ciertos productos de PC HP, que podrían permitir la ejecución de código arbitrario, la escalada de privilegios, la denegación de servicio y la divulgación de información.

- VECTOR DE ATAQUE: Local
- COMPLEJIDAD DEL ATAQUE: Alto
- PRIVILEGIOS REQUERIDOS: Bajo
- INTERACCIÓN CON EL USUARIO: Ninguno
- ALCANCE: Integrado
- IMPACTO DE LA CONFIDENCIALIDAD: Alto
- IMPACTO EN LA INTEGRIDAD: Alto
- IMPACTO EN LA DISPONIBILIDAD: Alto

MODELO: Dell Latitude 5440

VULNERABILIDAD: **CVE-2023-43078**

CRITICIDAD: **ALTO (7,3)**

DESCRIPCIÓN:

El firmware de la estación de acoplamiento Dell y la plataforma de cliente de Dell contienen una vulnerabilidad de resolución de enlaces incorrecta durante la instalación, lo que provoca la eliminación arbitraria de carpetas, lo que podría provocar una escalada de privilegios o una denegación de servicio.

Si un atacante logra acceder al firmware y comprende el patrón de error en la gestión de enlaces simbólicos durante la eliminación de carpetas, podría manipular el proceso para eliminar archivos críticos que comprometen la seguridad y la integridad del sistema.

Entre los objetivos potenciales se incluyen:

- Archivos de configuración del sistema
- Registros de actividad (logs), incluyendo evidencia de acciones maliciosas
- Componentes de software de seguridad, como antivirus
- Reglas y configuraciones de firewall

- VECTOR DE ATAQUE: Local
- COMPLEJIDAD DEL ATAQUE:Bajo
- PRIVILEGIOS REQUERIDOS: Alto
- INTERACCIÓN CON EL USUARIO: Ninguno
- ALCANCE: Inalterado
- IMPACTO DE LA CONFIDENCIALIDAD: Alto
- IMPACTO EN LA INTEGRIDAD: Alto
- IMPACTO EN LA DISPONIBILIDAD: Alto

VULNERABILIDAD: CVE-2024-0158

CRITICIDAD: **MEDIO (6,7)**

DESCIPCIÓN:

El BIOS de ciertos equipos Dell presenta una vulnerabilidad de validación incorrecta de entrada (CWE-20). Esta falla permite que un usuario local autenticado con privilegios de administrador modifique variables UEFI de forma no autorizada.

La explotación de esta vulnerabilidad puede provocar:

- Denegación de servicio (DoS) al alterar el comportamiento del firmware
- Escalada de privilegios, permitiendo al atacante ejecutar acciones con mayor nivel de acceso que el originalmente concedido

VECTOR DE ATAQUE: Local

COMPLEJIDAD DEL ATAQUE: Bajo

PRIVILEGIOS REQUERIDOS: Alto

INTERACCIÓN CON EL USUARIO: Ninguno

ALCANCE: Alto

IMPACTO DE LA CONFIDENCIALIDAD: Alto

IMPACTO EN LA INTEGRIDAD: Alto

IMPACTO EN LA DISPONIBILIDAD: Alto

VULNERABILIDAD: CVE-2024-22448

CRITICIDAD: MEDIA (4,7)

DESCRIPCIÓN:

El BIOS de Dell contiene una vulnerabilidad de escritura fuera de límites. Un usuario malintencionado autenticado local con privilegios de administrador podría aprovechar esta vulnerabilidad, lo que provocaría la denegación de servicio.

Si un atacante con acceso al firmware desborda la memoria de una variable puede sobrescribir partes de la memoria o incluso corromperla, generando una denegación de servicios.

- VECTOR DE ATAQUE: Local
- COMPLEJIDAD DEL ATAQUE: Alto
- PRIVILEGIOS REQUERIDOS: Alto
- INTERACCIÓN CON EL USUARIO: Ninguno
- ALCANCE: Integrado
- IMPACTO DE LA CONFIDENCIALIDAD: Ninguno
- IMPACTO EN LA INTEGRIDAD: Bajo
- IMPACTO EN LA DISPONIBILIDAD: Alto

MODELO: Dell Precision 5690 – Intel Core i9

VULNERABILIDAD: CVE-2025-20103

DESCRIPCIÓN:

Un grupo de recursos insuficiente en el mecanismo de administración central para algunos procesadores Intel(R) puede permitir que un usuario autenticado habilite potencialmente la denegación de servicio a través del acceso local.

- VECTOR DE ATAQUE: Local
- COMPLEJIDAD DEL ATAQUE: Bajo
- PRIVILEGIOS REQUERIDOS: Bajo
- INTERACCIÓN CON EL USUARIO: Ninguno
- ALCANCE: Cambiado
- IMPACTO DE LA CONFIDENCIALIDAD: Ninguno
- IMPACTO EN LA INTEGRIDAD: Ninguno
- IMPACTO EN LA DISPONIBILIDAD: Alto